

Politique de gouvernance des données et de conformité RGPD

Mémoire OSINT

Cellule de veille documentaire fictive

Edouard Cappaert · Bloc 1 · Version 1.3 · 4 octobre 2026

Ce plan encadre l’Observatoire TASS local : collecte d’articles, consultation, exports et exploitation des résultats NER. Il relie les décisions de la cellule de veille aux contrôles disponibles dans les blocs techniques.

Statut : étude de cas et politique proposée. Rôles, durées et objectifs restent des hypothèses. Les preuves techniques locales sont distinguées des procédures à réaliser. Aucune approbation de direction, nomination réelle de DPO, formation ou conformité globale n’est revendiquée. Grille d’utilisation associée : Grille_utilisation_gouvernance.md.

Sommaire

Section	Page
1 Introduction et contexte stratégique	2
2 Références réglementaires et normatives	3
3 Parties prenantes et responsabilités	4
4.1 Qualité des données et gouvernance de l’IA	5
4.2 Sécurité et prestataires	6
4.3 Vie privée et registre des traitements	7
4.4 Conservation droits et accessibilité	8
5.1 et 5.2 Identification et évaluation des risques	9
5.3 Traitement de chaque risque	10
5.4 Incidents et continuité	11
6 Audit formation et amélioration continue · 7 Conclusion	12
Résumé visuel intégré	13 et 14
Références	15
Extension TASS : gouvernance et preuves	16

1 Introduction et contexte stratégique

1.1 Finalité et périmètre

La cellule fictive appartient à un petit organisme privé établi en France. Deux utilisateurs métier, un analyste et un responsable de veille, explorent des mentions d'armes, d'unités et d'organisations militaires pour rédiger des notes sourcées. La direction de cet organisme est responsable des décisions de traitement. Les fonctions techniques et de conseil sont décrites p. 4, sans création d'une organisation réelle.

Le périmètre couvre le corpus historique, la collecte réseau TASS du bloc 3, le catalogue SQLite, ses versions et exports, les stockages B2, annotations, modèles, index et restitution. Le mini-site fonctionne sur le poste. Profilage individuel, décisions automatisées sur les personnes et surveillance opérationnelle restent exclus. Toute extension de source ou de finalité exige une revue [P5].

1.2 État documenté au 4 octobre 2026

Objet	État et classement proposé
Corpus historique	21 742 articles bruts ; 21 676 nettoyés après 66 rejets. Les 1 889 identifiants sélectionnés concordent avec le notebook. Ces contrôles ne mesurent pas la qualité NER.
Collecte et catalogue B3	Rubriques, dates UTC, mots-clés et limite. La recette réelle ajoute cinq articles : catalogue et stockages B2 à 21 681 articles dans les preuves du 4 octobre [P5].
Modèle et restitution	Baseline locale de démonstration B4 : 39 511 mentions sur les 21 676 articles historiques. Les cinq nouveaux articles ne sont pas analysés dans cette recette. Qualité humaine indépendante non établie [P6].
Archives et confidentialité	Artefacts historiques incomplets, distincts de la baseline reconstruite. Documents B2 chiffrés. Volume AES-256 B3 préparé ; activation et migration non attestées ici. Anciennes clés retirées du notebook copié, révocation non attestée.

Les nombres ci-dessus décrivent les versions de recette, pas un compteur permanent. Les empreintes des preuves et du code consultés figurent dans Preuves/Harmonisation_bloc3.json. Les droits d'usage et l'analyse juridique restent à établir.

1.3 Objectifs et limites

RV définit le besoin et autorise un périmètre dans le scénario. AN sélectionne rubrique, dates, mots-clés et limite dans Collecte, consulte Suivi puis lit les articles et versions dans Corpus. Un export ou import B2 prépare la suite ; il ne lance ni inférence ni entraînement B4. RV relit toute note avant diffusion.

TASS constitue une source unique : les fréquences reflètent ses publications, leur couverture et les erreurs d'extraction. Elles ne mesurent pas un inventaire militaire réel. Les articles peuvent citer des personnes physiques, même si les trois labels visés ne portent pas sur elles. Une donnée publiée reste susceptible d'être une donnée personnelle [S1, S3].

2 Références réglementaires et normatives

2.1 Applicabilité et mécanismes retenus

Référence et portée	Application dans le scénario
RGPD et loi Informatique et Libertés [S1, S2]	Cadre contraignant pour les données personnelles. Finalités et base légale p. 7, minimisation p. 5, droits et durées p. 8, sécurité p. 6, incidents p. 11. Registre et analyse des risques documentés.
Réutilisation et scraping [S3, S17, S18]	Vérifier provenance, CGU, droits sur les textes, base légale et restrictions techniques. Consulter robots.txt et respecter les exclusions. Ces contrôles ne valent pas licence de redistribution. Collecte bornée et diffusion intégrale exclue avant clarification.
Règlement européen sur l'IA [S10]	Qualifier l'usage et les rôles de fournisseur ou déployeur avant exploitation. Le cas de recherche documentaire décrit ne suffit pas à établir un usage à haut risque. Former aux limites de l'IA et conserver une supervision humaine. Réexaminer en cas de nouvelle finalité.
Accessibilité [S11]	Exigence explicite B1-1.2 et besoin utilisateur. RGAA utilisé comme méthode de contrôle. L'assujettissement légal dépend de l'organisme et du service ; le seul scénario fictif ne l'établit pas. Parcours et alternatives p. 8.
ISO/IEC 27001:2022 [S12]	Référence volontaire de management de la sécurité : risques, accès, incidents, continuité et amélioration. Aucune certification ni audit ISO complet revendiqué.
ISO/IEC 27701:2025 [S13]	Référence volontaire de management de la vie privée. L'édition 2025 remplace ici la référence historique de 2019 ; aucune conformité à toutes les clauses n'est revendiquée.
NIS 2 [S14]	Assujettissement à qualifier selon activité, taille et exceptions. Il ne découle pas du thème militaire des articles. Aucune obligation NIS 2 spécifique n'est attribuée automatiquement à cette cellule.

2.2 Règle de décision et veille

Pour chaque texte, RPD relie disposition, traitement, mécanisme et preuve. RV documente les restrictions TASS et le périmètre avant collecte. DIR arbitre les moyens. Revoir aussi tout changement de pagination, CGU ou robots.txt, sans assimiler une API interne du site à une autorisation contractuelle [P5].

Le calendrier du règlement IA a évolué en 2026. La page officielle de la Commission consultée décrit une application générale au 2 août 2026 avec exceptions et des échéances distinctes pour le haut risque. La qualification doit utiliser le texte en vigueur avant exploitation [S10].

3 Parties prenantes et responsabilités

3.1 Fonctions du scénario

DIR : direction de l'organisme, représentant le responsable de traitement. Elle décide des finalités, moyens, risques acceptés et notifications. **RV** : responsable de veille, propriétaire métier des données et valideur des synthèses. **AN** : analyste, chargé de la qualité et des annotations. **TECH** : administration, données et modèle. **RPD** : référent protection des données, conseil et contrôle. Si un DPO est désigné, il exerce ses missions avec indépendance ; il ne se substitue pas à DIR et ne détermine pas les finalités [S1, art. 37-39].

Personnes citées, éditeur TASS, titulaires des droits, école et jury, hébergeur éventuel et prestataire sont les parties externes. TASS fournit la source et n'est pas un sous-traitant de la cellule. Les rôles AN/RV restent organisationnels : le mini-site local n'implémente pas de comptes individuels.

3.2 Matrice de responsabilités

Décision ou opération	DIR	RV	AN	TECH	RPD
Finalités base légale et AIPD	A	R	C	C	C
Sources licence et périmètre de collecte	A	R	C	C	C
Qualité et relecture des annotations	I	A	R	C	C
Accès et départ d'un utilisateur	I	A	I	R	C
Entraînement et publication du modèle	I	A	C	R	C
Export import B2 et diffusion des notes	I	A	R	R	C
Demande de droits et effacement	A	R	C	R	C
Qualification et notification incident	A	R	I	R	C
Restauration et reprise	I	A	C	R	C
Audit veille et risque résiduel	A	R	C	C	R

A : décide et rend compte. R : réalise. C : consulté. I : informé. Une seule autorité A par ligne. Deux R peuvent contribuer avec des tâches distinctes : TECH exécute l'effacement ou contient l'incident, RV coordonne et consigne la décision. Le RPD tient la veille ; RV rassemble les preuves d'audit.

3.3 Organisation du travail

RV tient le registre des décisions et réunit mensuellement DIR, TECH et RPD pendant 30 minutes. Les incidents graves déclenchent une réunion immédiate. Toute décision comporte date, objet, version, avis, responsable, échéance et preuve attendue. Un rôle peut être cumulé dans une petite équipe, mais une personne ne clôt pas seule une correction qu'elle a réalisée : RV ou un relecteur distinct la vérifie.

Au lancement, AN relève job_id et paramètres approuvés. Pour un export, AN décrit sélection et destination ; RV donne son visa ; TECH exécute l'import B2. Le visa, la liste des utilisateurs et le suivi des copies restent des procédures proposées, sans bouton d'approbation existant.

4 Politiques et procédures de gestion des données

4.1 Qualité des données et gouvernance de l'IA

Procédure Q01. RV justifie source, rubrique, période UTC, mots-clés et limite avant acquisition. TECH vérifie restrictions et provenance. Le collecteur borne requêtes et reprises, puis valide les articles avant publication. Un taux de rejets supérieur au seuil configuré bloque le lot ; 20 % est un choix du projet [P5].

Contrat de données cible	Contrôle et preuve
id, source, url, date	ID source stable, URL et date UTC. Pour la collecte : job_id, paramètres, date d'acquisition et version d'extracteur. Séparer publication et collecte.
text et empreintes	Texte rattaché à sa source, empreinte et revision_sha256. Catalogue courant et anciennes versions inventoriés. Rejets, filtres et doublons comptés.
annotation et entités	article_id, version du texte, start/end, label parmi WEAPON, MIL_UNIT, MIL_ORG, auteur de validation et date. Vérifier que le segment correspond exactement au texte.
exécution modèle et résultat	run_id, versions corpus/annotations/configuration/code/modèle, graine, métriques et date. Le dashboard expose le périmètre réellement traité.

Annotation Q02. AN rédige des consignes et relit au moins 50 articles, ou tout le lot plus petit, en couvrant les trois labels et des négatifs. Conserver tirage, auteur, date, désaccords et corrections. Ce choix du scénario reste à réaliser ; la supervision faible de la baseline B4 ne remplace pas cette validation humaine [P6].

Validation Q03. TECH conserve jeux séparés, versions et métriques par label. RV examine les erreurs et motive l'acceptation. Les scores historiques ne sont pas reproduits ; les sorties de démonstration ne prouvent pas une qualité sur référence humaine. Aucun seuil de certification n'est inventé [P6].

Règle de restitution. Le filtre temporel s'applique aux articles et aux mentions. Chaque mention reste reliée à un extrait consultable. Les notes précisent source unique, dates, dénominateurs et limites. Le responsable valide la note avant diffusion ; aucune conclusion sur une personne n'est générée automatiquement.

Minimisation : rubriques publiques TASS en anglais, dates UTC inclusives, limites de pages et d'articles, cadence et robots.txt. Conserver titres, textes et métadonnées utiles, sans collecte séparée d'images, profils, coordonnées ou biographies. Les mots-clés filtrent après téléchargement ; les payloads hors filtre sont retirés. Les données personnelles ou sensibles dans les articles acceptés ne sont pas automatiquement détectées ni anonymisées [S18, P5].

4.2 Sécurité des données et prestataires

Accès selon le besoin

Cible organisationnelle : RV approuve nominativement les accès, TECH les liste et les révoque, cible de 24 heures après départ signalé. Le mini-site ne sépare pas AN/RV et ne possède pas de comptes applicatifs individuels. Les traces portent le compte système du serveur : une session partagée n'identifie pas chacun. Utiliser une session nominative.

Configuration cible et vérification

Contrôles disponibles : boucle locale, Host, origine, jeton CSRF, permissions restrictives et refus 403 testés [P5]. Le jeton n'authentifie pas une personne. Un volume macOS AES-256 dédié aux états, journaux, exports et secours B3 est préparé. Activation, migration et empreintes restent à vérifier après saisie personnelle du mot de passe dans Terminal. Le lanceur exige le volume monté, sans remplacement en clair. Cela ne chiffre ni tout le Mac ni les copies externes.

Le chiffrement des documents B2 ne protège pas les copies B3. Avant accès distant ou partagé : authentification, autorisations, TLS avec certificats vérifiés et MFA d'administration si disponible. Secrets hors code, rotation des clés historiques et révocation des accès restent requis [P4].

Prestataires et transferts

Procédure S01. Avant un envoi à un LLM ou à un hébergeur, RV décrit les champs transmis et la finalité. RPD vérifie le rôle contractuel, l'accord de sous-traitance si applicable, les sous-traitants ultérieurs, les lieux de traitement et d'accès support, la conservation et l'usage éventuel pour entraîner le fournisseur. DIR autorise le prestataire sur dossier [S8].

Un hébergement annoncé en Europe ne suffit pas à écarter les transferts. Tout accès depuis un pays tiers est examiné ; le mécanisme du chapitre V, l'analyse du transfert et les mesures complémentaires sont documentés lorsque nécessaires. Sans garanties établies, aucun nouveau texte personnel n'est transmis à ce service. La préannotation externe est facultative : une annotation locale reste possible [S9].

Journalisation et diffusion

Procédure E01 proposée. AN relève filtre, nombre, destinataire, motif et échéance ; RV autorise ; TECH conserve export_id et empreinte. L'export peut dépasser la limite du dernier job. Pas de partage intégral sans droits établis. Consultations, exports et droits sont journalisés avec compte système, date, résultat et références, sans texte, secret ni mots-clés libres. Copies externes et visa métier restent suivis manuellement [P5].

4.3 Confidentialité et protection de la vie privée

Registre initial du scénario

Traitement et finalité	Données personnes et destinataires
T01 Collecte veille et synthèse	Acquisition TASS, textes, versions et mentions pouvant citer des personnes. AN/RV, TECH au besoin. Intérêt légitime proposé, à documenter pour acquisition et consultation.
T02 Annotation entraînement évaluation	Textes et annotations liés à T01. AN et TECH ; fournisseur uniquement après S01. Intérêt légitime à apprécier séparément pour le développement du modèle.
T03 Sécurité et traçabilité	Compte système du serveur, dates, résultats et références techniques, sans textes ni mots-clés libres. TECH/RV/RPD au besoin. Intérêt légitime de sécurisation. Pas de comptes applicatifs ni identification individuelle sur session partagée.
T04 Droits et violations	Coordonnées nécessaires, demande, décisions et preuves limitées. DIR, RV, RPD, TECH pour exécution. Obligation légale de répondre et documenter [S1].

RV complète contact réel, sources, systèmes, catégories, destinataires, bases, transferts, durées et mesures. T01 inclut SQLite B3, exports et import B2. Une collecte ne déclenche pas T02 ; toute réutilisation pour entraîner exige sa décision distincte. Registre proposé, sans déclaration à la CNIL.

Intérêt légitime et données sensibles

Analyse initiale T01/T02. Justifier intérêt, nécessité et mise en balance pour collecte documentaire et développement du modèle séparément. Textes nécessaires à la vérification, images et profils exclus. Risques : réexposition, anciennes versions, export ou inférence trompeuse. Garanties : périmètre borné, accès local, relecture et droits [S4, S17].

Décision proposée : base non validée sans analyse des attentes et des contenus. Le consentement n'est pas automatique. Des données sensibles ou pénales doivent être isolées et exclues tant qu'un fondement applicable manque. Une publication par un média ne vaut pas publication manifeste par la personne. Ce tri n'est pas automatisé dans B3 [S1, art. 9-10].

Analyse d'impact et information

RPD évalue la nécessité d'une AIPD selon usages, échelle et risques, notamment données sensibles ou personnes vulnérables. Le scénario retient sa réalisation avant extension à grande échelle ou envoi externe. DIR arbitre. Ni l'IA seule ni le cadre scolaire ne règlent automatiquement cette qualification [S5].

RV prépare une notice avec responsable/contact, sources, finalités, bases, catégories, destinataires, transferts, durées, droits et recours CNIL. Information art. 14 : au plus tard dans le mois, ou plus tôt au premier contact ou à la communication. Une exception exige justification et garanties. Le mini-site local ne fournit pas actuellement de notice pour les personnes citées ; la publier et prévoir un canal effectif restent des actions proposées [S6].

4.4 Conservation droits et accessibilité

Durées proposées et justifications

Données	Durée proposée	Justification et fin de vie
Corpus versions annotations modèles index	12 mois après la dernière soutenance	Choix pour reproduction du mémoire, à revoir si veille durable. Inclut SQLite et exports B3. Purge coordonnée, non automatisée par échéance.
Journaux techniques et accès	6 mois glissants	Diagnostic et sécurité. Purge au démarrage puis quotidienne hors worker actif : six mois calendaires. Purge testée ; délai réel de 24 h non observé.
Dossiers de droits et incidents	12 mois après clôture	Preuve du traitement, minimisée. Conservation litigieuse séparée uniquement si nécessité justifiée.
Sauvegardes	30 jours glissants	Restauration. Purge à expiration ; liste des effacements à réappliquer avant toute remise en service.

Ces durées sont des choix du scénario, pas des délais légaux universels. RV documente nécessité et départ. Les décisions actives de correction/exclusion sont conservées séparément tant que nécessaires contre la réintroduction, puis réexaminées. Le calendrier des corpus et copies externes reste à mettre en œuvre [S7].

Procédure D01 pour une demande de droits

1. RV reçoit la demande sur le contact prévu dans la notice, ouvre un numéro et accuse réception. Il ne demande une pièce d'identité que si un doute raisonnable le justifie.
2. RPD qualifie accès, rectification, opposition, limitation ou effacement. La portabilité n'est pas générale pour T01/T02 fondés sur l'intérêt légitime.
3. TECH recherche les articles et dérivés par identifiant, texte et versions : corpus, annotations, jeux, index, exports et fournisseurs. DIR décide ; RV répond dans le délai applicable d'un mois. Une prolongation jusqu'à deux mois supplémentaires doit être justifiée et annoncée dans le premier mois [S1, S15].
4. Après une décision d'effacement, TECH retire les copies actives, propage aux destinataires concernés et consigne la purge différée des sauvegardes. Si le modèle peut restituer la donnée, suspendre sa diffusion et évaluer son remplacement ou réentraînement. Ne pas promettre un effacement des poids sans preuve.
5. RV contrôle la disparition des résultats et clôt avec date, périmètre, exceptions motivées et information de recours. Un dossier sans preuve de propagation reste ouvert.

Accessibilité et inclusion

RV contrôle Collecte, Suivi, Corpus, dialogue article et exports au clavier, focus, zoom, contrastes et lecture des tableaux. Prévoir descriptions, sous-titres et transcription pour les preuves visuelles. Des tests Chrome de disposition jusqu'au zoom CSS 200 % sont enregistrés [P5] ; ils ne démontrent ni audit RGAA complet, lecteur d'écran, zoom natif ni test avec une personne concernée. TECH corrige puis RV refait le parcours [S11].

Application D01 : après décision, TECH utilise collect-access, collect-rectify ou collect-erase avec ID et référence opaque ; coordonner la propagation B2. Tests fictifs : anciennes versions, tâches, exports gérés, copie de secours, rejeu et restauration ; registre de correction B2 chiffré. Recherche par personne, annotations, modèles, sources et copies externes restent coordonnés. Purge logique et recherche SQLite/WAL ne prouvent pas l'effacement physique du SSD [P5, P6].

5 Gestion des risques liés aux données

5.1 Méthode de cotation

La probabilité P et l'impact I sont estimés de 1 à 4 pour ce scénario. P : peu plausible, possible, plausible avec défaut observé, fréquent. I : gêne limitée, atteinte réversible, atteinte majeure, atteinte grave aux personnes ou perte majeure. La criticité est $P \times I$. Cotation initiale qualitative, sans fréquence mesurée.

Choix interne : scores 1 à 3, surveillance ; 4 à 7, traitement planifié ; 8 à 16, traitement prioritaire avant l'usage concerné. Une obligation légale non satisfaite bloque cet usage quel que soit le score. Aucun score résiduel n'est considéré atteint avant contrôle des mesures.

5.2 Cartographie couvrant le cycle de vie

ID	Cause ou situation	Impact principal	$P \times I$
R01	Clés historiques ou copies B3 exposées	Divulgaration de textes, contrôle local insuffisant	$3 \times 4 = 12$
R02	Scraping finalité base ou licence mal qualifiés	Collecte ou redistribution injustifiée	$3 \times 4 = 12$
R03	Transfert LLM ou cloud mal encadré	Réutilisation externe et perte de maîtrise des copies	$3 \times 4 = 12$
R04	Annotations erronées et source unique	Synthèse trompeuse, réexposition de personnes citées	$3 \times 3 = 9$
R05	Versions dates ou couverture mal interprétées	Extraits obsolètes, dénominateurs erronés	$3 \times 3 = 9$
R06	Perte des fichiers ou effacement d'index	Résultats impossibles à reproduire et indisponibilité	$3 \times 3 = 9$
R07	Export au mauvais destinataire ou poste partagé	Divulgaration et copie hors contrôle du catalogue	$2 \times 4 = 8$
R08	Versions exports ou files d'attente non purgés	Conservation excessive et réapparition en recollecte	$2 \times 3 = 6$
R09	Interface ou support inaccessible	Exclusion d'un utilisateur ou d'un membre du jury	$2 \times 3 = 6$
R10	Changement TASS du droit ou de la finalité	Collecte inadaptée ou extension non évaluée	$2 \times 4 = 8$

R01, R05 et R06 s'appuient sur les défauts historiques. B3 ajoute copies locales, versions, exports et secours. Le volume chiffré préparé ne clôt pas le risque sans activation attestée. Cotations estimées, sans incident réel affirmé. Revoir après toute évolution de source, CGU, utilisateur, corpus, modèle ou finalité [P4, P5].

Un prestataire ou une assurance ne transfère pas la responsabilité réglementaire de l'organisme. DIR peut accepter un risque résiduel compatible avec le droit, en documentant motif, durée et révision. Le référent conseille et contrôle cette décision.

5.3 Traitement de chaque risque

Les stratégies couvrent les dix risques. Certains mécanismes disposent de preuves locales [P5, P6], sans clôture globale : permissions et CSRF ne prouvent pas le chiffrement B3 ; l'exclusion d'un ID ne prouve pas la purge de toutes les copies. DIR arbitre et RV conserve le résultat de chaque contrôle.

ID	Stratégie	Mesures et pilote	Échéance	Preuve et cible résiduelle
R01	Réduire	Rotation clés, Host/CSRF et permissions ; activer et contrôler le volume AES-256 B3 préparé. TECH	Avant appel ou accès distant	Preuve expurgée de rotation et tests ; cible 1 × 4 = 4
R02	Éviter puis réduire	Qualifier CGU, droits, base et périmètre ; respecter exclusions réseau. DIR/RPD	Avant nouvel usage ou diffusion	Analyse et décision motivées ; cible 1 × 4 = 4
R03	Éviter puis réduire	Suspendre envois non encadrés, vérifier S01 et transferts, minimiser le texte. RV/TECH	Avant chaque prestataire	Contrat et cartographie des accès ; cible 1 × 4 = 4
R04	Réduire	Relecture humaine stratifiée, erreurs par label, limites visibles et validation des notes. AN/RV	Avant entraînement et note	Fiche Q02 et protocole Q03 ; cible 2 × 3 = 6
R05	Réduire	Tracer job, empreintes, révisions et UTC ; vérifier couverture et nouvelle inférence si texte changé. TECH	Avant indexation validée	Rapport de tests article par article ; cible 1 × 3 = 3
R06	Réduire	Secours local de lecture testé ; sauvegarde hors poste et restauration coordonnées à organiser. TECH	Avant démonstration	Manifestes et procès-verbal de restauration ; cible 1 × 3 = 3
R07	Réduire	Visa E01, destinataire, accès poste et inventaire des copies ; comptes distincts avant partage. RV/TECH	Avant accès ou partage	Liste des accès et visa export ; cible 1 × 4 = 4
R08	Réduire	Purger versions tâches exports gérés ; registre d'exclusion, suivi copies externes et calendrier. TECH/RV	À chaque échéance et droit	Journal de purge et recherche de contrôle ; cible 1 × 3 = 3
R09	Réduire	Tester parcours, alternatives textuelles, sous-titres et corrections. RV/TECH	Avant remise et interface	Relevé des obstacles et contre-tests ; cible 1 × 3 = 3
R10	Éviter puis réduire	Veille juridique et TASS ; arrêter avant contournement et revoir nouvelle source ou finalité. DIR/RPD	Mensuel et à tout changement	Journal de veille et décision ; cible 1 × 4 = 4

Après vérification, RV renseigne date, résultat, preuve, cotation résiduelle observée, avis RPD et décision DIR. Les cibles ci-dessus sont des estimations, pas des scores constatés. Revue mensuelle tant qu'un risque prioritaire reste ouvert, puis trimestrielle. Toute preuve absente maintient la mesure au statut prévu.

Ordre de réalisation : sécuriser les identifiants et les flux ; qualifier usages et prestataires ; récupérer ou reconstruire les artefacts ; valider qualité et restitution ; tester continuité, droits et accessibilité. Ces dépendances relient le plan du bloc 1 aux réalisations des blocs 2, 3 et 4.

5.4 Incidents et plans de contingence

I01 Violation de données ou non conformité

1. Toute personne alerte immédiatement RV et TECH. RV ouvre un dossier avec heure de détection et de prise de connaissance, systèmes, faits et personnes potentiellement concernées. TECH préserve les journaux, isole les accès compromis et fait révoquer les clés sans détruire les preuves.
2. DIR, conseillé par RPD, distingue panne, violation de données et non-conformité de licence ou de finalité. Il évalue catégories, volume, conséquences et risque pour les personnes. Toutes les violations de données sont documentées, même sans notification.
3. Si la violation est susceptible d'engendrer un risque pour les droits et libertés, DIR organise la notification à la CNIL dans les meilleurs délais et, si possible, au plus tard 72 heures après en avoir pris connaissance. Une notification progressive est possible ; un retard est motivé. L'absence de risque est justifiée et enregistrée [S1, S16].
4. En cas de risque élevé, informer les personnes sans retard injustifié, sous réserve des exceptions de l'article 34. Le délai de 72 heures ne constitue pas un délai universel de communication aux personnes. Prévoir une formulation accessible et des conseils adaptés.
5. Une non-conformité sans violation déclenche suspension de l'usage, correction, information des responsables et nouvelle revue. RV clôt seulement après vérification des mesures et réexamen du risque.

C01 Panne perte ou corruption des artefacts

Hypothèses de service proposées : RTO de 8 heures ouvrées pour rétablir l'accès utile et RPO de 24 heures pour les fichiers en cours. Elles correspondent à une veille quotidienne différable et doivent être testées. Le corpus source et chaque modèle accepté font l'objet d'un archivage après validation ; les travaux actifs d'une sauvegarde quotidienne chiffrée, distincte du poste.

TECH interrompt les écritures, identifie une version saine et restaure en environnement isolé. Il vérifie empreintes, volumes, chargement du modèle, absence de données à effacer et un parcours article/extrait. RV autorise la reprise et informe les utilisateurs. Sans restauration valide, le mode dégradé consiste à consulter les sources déjà vérifiées et à suspendre les indicateurs non fiables. Exercice avant démonstration puis trimestriel, jamais déclaré réalisé sans procès-verbal.

C02 Résultat IA trompeur ou export erroné

RV retire la note ou le résultat concerné, avertit ses destinataires et consigne la correction. TECH fige la version et analyse le périmètre ; AN vérifie les annotations et erreurs. La reprise exige une évaluation et une validation de RV. Si une divulgation accompagne l'erreur, appliquer aussi I01. Un F1 seul n'autorise pas à déclarer fiables toutes les tendances.

Cas B3 : suspendre devant refus ou changement TASS, sans contournement. Reprise du worker et lecture/export sur copie saine testés ; collecte, import et droits bloqués en secours. Restauration explicite serveur arrêté, intégrité et registres appliqués avant exposition. Alertes de permissions et d'intégrité reliées à I01 ; tests fictifs de confinement, sans notification réelle. Restauration B2 isolée documentée, perte du Mac non couverte [P5].

6 Audit contrôle et amélioration continue

6.1 Programme de contrôle

Quand et responsable	Contrôle et trace à conserver
Avant accès puis annuel · RV/RPD	Formation de 45 minutes sur données publiques, limites NER, partage, droits et incidents. Exercice sur une note sourcée et une demande de droits ; feuille de présence et corrections.
À chaque lot · AN/TECH	Q01-Q03 : qualité, offsets, versions et évaluation. RV accepte ou renvoie le lot avec motif.
Mensuel · RV avec TECH/RPD	Accès, incidents, purges, risques ouverts et veille officielle. Ticket par écart avec responsable et date.
Trimestriel et avant remise · relecteur distinct	Audit : cadrage du périmètre, revue de preuves, entretiens, tests ciblés, constats, contradictoire, corrections et contre-tests. Clôture validée par DIR.

La Grille_utilisation_gouvernance.md relie sept parcours à leurs acteurs, règles, contrôles et limites. Les tests locaux couvrent collecte, droits fictifs, refus Host/CSRF, alertes et secours. Visa d'export, formation, examen juridique, test utilisateur et revue indépendante restent à réaliser [P5, P6].

6.2 Indicateurs proposés

RV suit acceptés/téléchargés, rejets et hors filtre ; jobs avec périmètre validé/jobs lancés ; exports avec visa/exports partagés ; versions et copies purgées/copies concernées ; droits dans le délai/demandes échues ; restaurations réussies/tentatives ; obstacles d'accessibilité ouverts. Les compteurs techniques existent, les ratios d'autorisation et de droits restent à organiser. Dénominateur nul : « non applicable ».

6.3 Veille et amélioration

RPD consulte mensuellement CNIL, EUR-Lex, Légifrance, Commission, ANSSI, ISO et RGAA [S1-S18]. TECH relève les changements TASS de CGU, robots.txt et extraction. Documenter date, version, traitements touchés, action, pilote et échéance. DIR décide et RV actualise les supports. Toute nouvelle source, finalité ou destination déclenche une revue.

7 Conclusion et état de cette version

La V1.3 intègre le mini-site et les protections B3/B2 en conservant les limites : droits d'usage, analyses juridiques, notice, validation humaine, activation du volume B3, purge par échéance hors journaux, copies externes et sauvegarde hors poste. Aucune conformité globale ni répétition orale attestée.

Repères : OSINT : analyse de sources ouvertes. NER : extraction d'entités nommées. AIPD : analyse d'impact sur la protection des données. DPO : délégué à la protection des données. RTO : délai cible de reprise. RPO : perte de travail maximale visée.

Résumé visuel de la stratégie

Une note doit rester reliée à ses sources

AN choisit une collecte bornée, suit le job puis consulte les textes. RV autorise périmètre et diffusion dans le scénario. Le lien article, version et preuve accompagne chaque note.

Étape	Décision de gouvernance	Preuve attendue
1 Acquérir	Source et périmètre justifiés	Paramètres, job et restrictions
2 Préparer	Rejets et transformations expliqués	Contrat et journal de qualité
3 Annoter	Relecture humaine effective	Échantillon et corrections
4 Évaluer	Données et modèle identifiés	Protocole et erreurs par label
5 Restituer	Article et extrait retrouvables	Filtre et dénominateur vérifiés
6 Effacer	Versions et copies suivies	Purge et exclusion de recollecte

État vérifié

21 676 articles historiques nettoyés
Cinq articles ajoutés dans la recette B3
21 681 articles dans le catalogue et B2 [P5]

À compléter

Droits d’usage, analyses juridiques, validation humaine, activation vérifiée du volume B3, copies externes et contrôle complet d’accessibilité restent à établir.

Source unique TASS. Les mentions décrivent un corpus éditorial ; leurs fréquences ne prouvent pas l’activité réelle des acteurs.
[P4]

Résumé visuel des responsabilités et des risques

La décision revient au responsable du traitement

Fonction	Responsabilité essentielle
Direction	Décider des finalités, moyens et risques acceptés
Responsable de veille	Valider les notes et vérifier les preuves
Analyste	Contrôler les textes et relire les annotations
Équipe technique	Protéger les accès et tracer les transformations
Référent ou DPO	Conseiller et contrôler avec indépendance

Priorités avant utilisation

R01 à R03 : protéger les copies locales, qualifier collecte et droits d'usage, encadrer toute transmission externe.

R04 à R06 : relire les annotations, tracer les versions et distinguer checkpoints de sauvegardes.

R07 à R10 : autoriser les exports, suivre l'effacement et la recollecte, tester l'accessibilité et revoir tout changement.

En cas de violation

Contenir, documenter et évaluer le risque. DIR décide de la notification CNIL selon les conditions de l'article 33. Le RPD apporte son analyse. [S1, S16]

Références et traçabilité

Sources officielles consultées le 4 octobre 2026. Les liens ci-dessous permettent d'ouvrir les pages. Les normes ISO sont utilisées comme références de méthode ; leur texte intégral n'a pas fait l'objet d'un audit de conformité.

- S1** [RGPD, règlement \(UE\) 2016/679, notamment art. 5-6, 9-10, 12-22, 25, 28, 30, 32-39 et 44 et suivants](#)
- S2** [Loi du 6 janvier 1978 modifiée, Informatique et Libertés](#)
- S3** [CNIL, recommandations aux réutilisateurs de données publiées sur Internet](#)
- S4** [CNIL, intérêt légitime : nécessité et mise en balance](#)
- S5** [CNIL, IA : réaliser une analyse d'impact si nécessaire](#)
- S6** [CNIL, IA : informer les personnes concernées](#)
- S7** [CNIL, les durées de conservation des données](#)
- S8** [CNIL, contrats entre responsable de traitement et sous-traitant](#)
- S9** [CNIL, identifier et traiter les transferts hors UE](#)
- S10** [Commission européenne, AI Act, état du calendrier et des obligations](#)
- S11** [RGAA, référentiel et champ d'application](#)
- S12** [ISO/IEC 27001:2022, management de la sécurité](#)
- S13** [ISO/IEC 27701:2025, management de la vie privée](#)
- S14** [ANSSI, NIS 2, qualification des entités](#)
- S15** [CNIL, chapitre III du RGPD, droits des personnes](#)
- S16** [CNIL, notifier une violation de données personnelles](#)
- S17** [CNIL, intérêt légitime et collecte par moissonnage, 19 juin 2025](#)
- S18** [CNIL, protection des données dans la collecte et la gestion, 8 avril 2024](#)

Sources de l'école et du projet

P2 Grille évaluation RNCP38777, Bloc 1, cellules A6 à A27 : 22 critères. Consignes du directeur : plan et présentation, 15 minutes puis 15 minutes de questions. Le PDF qualité fourni porte RNCP41993 ; aucune substitution de grille n'est effectuée.

P4 Dossier 00_Pilotage : Cadrage_OSINT, Audit_et_ecarts, Recuperation_artefacts, Inventaire et Controle_reconstitution. Notebook historique : cellules N04, N06, N10, N12 et N19-N22. La nouvelle version nettoyée utilise UTC.

La correspondance complète des 22 critères figure dans Correspondance_criteres_Bloc1.csv. Les procédures écrites sont distinguées des exécutions observées. Les hypothèses de la cellule fictive ne décrivent pas une organisation réelle.

P1 Grille fournie RNCP38777, consignes de soutenance et sources locales identifiées dans le dossier de remise. La présence de données publiques ne suffit pas à exclure les données personnelles.

P5 Collecte_TASS.md et Execution_PRD_TASS.md ; B3 : Verification_HTTP.json, Reseau_final.json, Responsive_final.json, Tests_cloture_final.log, Droits_B3_B2.json et tests/closure.py (droits, secours, alertes). B2 : Revisions_collecte_TASS.json, Contrat_collecte_TASS.json et Collecte_TASS/restore.json. Voir P7 pour les empreintes et états au moment de lecture.

P6 00_Pilotage/Integration_transversale/README.md et Preuves/Controle_B3_B2_B4_complet.json : parcours NER et effacement synthétique. **P7** Grille_utilisation_gouvernance.md et Preuves/Harmonisation_bloc3.json : preuves, versions et frontières de la V1.2.

Extension TASS : gouvernance et preuves

Périmètre. Collecte locale bornée, catalogue versionné, exports gérés et secours B3. B2 reçoit les publications validées et les décisions de droits ; les modèles B4 sont conservés. Les copies déjà sorties du périmètre nécessitent une coordination.

Protection. Volume macOS AES-256 préparé et lanceur sans remplacement en clair. Activation et migration restent à constater après saisie personnelle du mot de passe dans Terminal. Comparaison d'empreintes et de comptes avant retrait de l'ancien état. Aucun chiffrement global du Mac ni effacement physique garanti du SSD affirmé.

Droits. Accès, rectification normalisée et suppression persistante. Purge des anciennes versions, tâches, exports et secours. La recollecte et la restauration ne peuvent rétablir automatiquement un texte invalidé. Propagation SQL/Mongo/index et restauration B2 testées sur un identifiant fictif [P8].

Audit et conservation. Compte système, date UTC, résultat et références techniques. Exclusion des textes, secrets, mots-clés libres et coordonnées. Journaux : six mois calendaires ; décisions actives séparées tant que nécessaires contre une réintroduction. Un compte partagé ne distingue pas les personnes et l'accès direct aux fichiers n'est pas audité.

Incident I01. Alertes de lenteur, permissions et intégrité reliées à la procédure. Exercice fictif : détection, confinement, qualification sans personne réelle concernée, restauration hors serveur et clôture technique. DIR/RPD qualifient le risque et une éventuelle notification ; aucun envoi réel n'a lieu [S16, P8].

Continuité. Consultation et export depuis une copie vérifiée, écritures bloquées. Restauration avec registres de droits avant remise en service. Même Mac et même volume ; perte du poste non couverte. La base légale, les droits d'usage, les copies externes et la conservation des corpus restent à qualifier.

P8 Preuves/Extension_collecte_TASS.json et B3 Preuves/Collecte_TASS : Version_finale.json, Droits_B3_B2.json, Verification_HTTP.json, Incident_simule.json et Volume_chiffre.json. Les preuves distinguent implémentation, tests, activation personnelle et préparation orale. Aucune conformité globale ou validation du jury n'est déclarée.